Support message

Not applicable · Sunday 12 October 2025 at 04:01

Our reply

Case number: 1838087146916736

Hi Jatin,

Due to how the internet operates, it is not always possible to retroactively prevent a person from accessing a photo after it has been delivered to their device. It might have been saved locally, stored in their browser cache, or temporarily cached in a nearby Content Delivery Network (CDN). These factors prevent us from retroactively restricting access to this data. We make a best effort to achieve this, but it is not foolproof. Your report describes one of the scenarios that we do not have any control over.

Thanks for taking the time to report this issue, and please let us know if you have any additional questions.

If you believe that we have made a mistake assessing this report, you can reopen this report by using one “reopening credit”, which will be refunded to you if the report gets accepted. You can learn more about reopening credits by visiting your Researcher Profile: https://www.facebook.com/whitehat/profile/

Thanks,

Meta Security

Sunday 12 October 2025 at 03:56

Our reply

Case number: 1838087146916736

Hi,

Thank you for reporting a security issue! Your report number is 1838087146916736. Please give us reasonable time to investigate and mitigate the issue before sharing information with others, and note that we reserve the right to publish your report. (More details: https://www.facebook.com/whitehat/.) Note that if you're writing to us in a language other than English, we'll only be able to respond in English at this time. We're sorry for any inconvenience this may cause.

If you're trying to report another issue, please review the information below to get help.

- If your account or a friend's account is sending out suspicious links: https://www.facebook.com/help/hacked

- To report abuse: https://www.facebook.com/help/reportlinks

- To report bugs that are not security issues: https://www.facebook.com/help/www/326603310765065

- For any other questions or concerns, please visit our Help Center: https://www.facebook.com/help

Thank you,

Meta Security

Sunday 12 October 2025 at 03:56

What you submitted

Case number: 1838087146916736

Title
Unauthenticated Access to Private Instagram Account Posts - Critical Privacy Bypass

Description/Impact
I discovered a critical vulnerability that allows any user to access private

DISCOVERY:
While conducting security research on Instagram's public APIs, endpoints, I discovered that private account content is accessible through a BASIC ENDPOINT [instagram.com/username]. The vulnerability allows direct access to post media URLs from private accounts without any form of authentication.

VULNERABILITY DETAILS:
- No Instagram login required
- No authentication token needed
- No follower relationship required
- Works on any private Instagram account
- Exposes direct CDN URLs to private post images
- The response contains full-resolution media URLs that are immediately accessible

VERIFICATION:
I have verified this vulnerability on my own private Instagram account to confirm reproducibility. The bug is consistent and can be exploited trivially by anyone with knowledge of the endpoint pattern.

SCOPE:
This affects all private Instagram accounts globally. Any user's private content can be accessed by anyone who knows their username, regardless of privacy settings.

I have not disclosed this vulnerability to anyone and have only tested it on my own account for verification purposes. I have attached a video demonstration showing the complete exploitation process on my personal account, and how exactly i discovered it.

PRIVACY VIOLATION:
- Complete bypass of Instagram's private account privacy feature
- Any person can view posts from any private account without permission
- Exposes personal photos, videos, and content users explicitly marked as private
- Users have no way to protect their content or detect unauthorized access

USER RISK:
- Millions of users with private accounts believe their content is protected
- No consent or authorization required to access their private posts
- Potential for stalking, harassment, and privacy violations
- Sensitive personal content (family photos, personal moments, location data) exposed
- Users cannot detect when their private content has been accessed

EXPLOITATION POTENTIAL:
- Trivially exploitable by anyone with basic technical knowledge
- No special tools or sophisticated techniques required
- Can be automated to scrape multiple accounts
- Could be weaponized for mass privacy violations

This represents a complete failure of Instagram's authorization model for private accounts and is one of the most severe privacy vulnerabilities possible on the platform.

Repro Steps

Environment: Standard Instagram environment in a private browser window, no special configuration required

Browser: Tested with Chrome , Brave. Works without a browser too.

OS: Not relevant

1. Navigate to instagram.com and verify you cannot see private account content through normal means (attempting to view a private profile shows "This Account is Private").

2. Open a FRESH private chrome window. Ensure you are completely logged out of Instagram (use incognito/private browsing mode to confirm no authentication).

3. While the network tab is opened , decrease the viewport area by increasing the size of the networks tab.

4. Finally load the private account by going to instagram.com/<username>. Replace <username> with actual username. Filter for "Doc" mode in the networks tab

5. Look for the latest /username request. Click on it and go to Response tab.

6. Search for "polaris_timeline_connection" in the response. Its inside a script tag, with application/json type. Within that you should see a structure you will see things like > edges > nodes > image_versions2. That node is a single post and image_versions are different qualities of that post.

7. Decode one of the links are those are escaped urls, and you should be able to see all private images that way.

NOTE: Full technical implementation is demonstrated in the attached video and POC script to prevent premature public disclosure of exact exploitation method.

See Options